

etudier sa mere

pare feu avec etat (statefull) → dispositif réseau qui va surveiller les connexion réseau (par ex : sessions udp et tcp), a l'inverse du stateless, il va garder les connexion active dans une table afin de prendre une décision (filtrer) avec le contexte de la session, par exemple : laisser passer un paquet de réponse pour une connexion déjà établie. Ca permet améliorer la sécurité et l'efficacité du filtrage. en laissant passer les connexion legitime et en bloquant les paquets malveillant/non voulu

en gros trafic de retour est automatiquement autorisé

VDOM : domaine virtuel (virtual domain) : Division d'un pare feu en segment logique, de tel manière a avoir des pare feu logique (virtuel) qui peuvent contenir leur propre configuration et fonctionner comme un pare feu normal (comme si on avait plusieurs VRAI pare feux) Ca permet de diviser en groupe par exemple pour différents secteur dans une entreprise. de base les vdom ne communiquent pas entre eux mais on peut les faire communiquer si on veut via des lien

Sécurité pour la connexion au fortigate :

- Activer l'A2F (Epic game nous l'a bien appris) → Fortitoken
- Activer les trusted host (ip spécifiques ou plage d'ip qui peuvent se connecter)
- Changer les ports de base (http(s) et ssh) ca permet d'éviter les attaques automatique sur ces ports
- Mettre une politique de mots de passe bien vénère S/O mdp de 50 caractère firewall groupes 8-9



FortiTelemetry → Pour la gestion des Forticlients (le nom il fait pitié) et de la *Security fabric*

L'agrégation de lien se fait via LACP

FSS (Fortiguard Subscription Services) contient :

- **FDN (Fortiguard Distribution Manager)** → Distribue les mise à jour

Caractéristique FSS :

- Mode d'accès par défaut → Anycast
- Connexion forcé via https (port 443)

UTM → Unified Threat Management (FW, IPS, antivirus, filtrage Web, DLP, ...)

FortiIPAM → permet d'attribuer automatiquement des adresses IP en fonction de la taille du réseau configuré. (Évite le chevauchement d'adresses dans le même Security Fabric)

Différents profils admin :

Critères	super_admin	prof_admin
Permissions	Accès total à toutes les fonctionnalités	Accès limité à son propre VDOM

Gestion globale	Peut configurer des paramètres globaux	Pas d'accès aux paramètres globaux
Modifications possibles	Ne peut pas être modifié ou supprimé	Peut être personnalisé

One-Arm Sniffer (de culotte) → Permet d'utiliser l'interface pour sniffer le trafic (ne peut pas envoyer de trafic)

Les 2 modes de fonctionnement d'un fortigate :

- Transparent (bridge)
 - Fonctionne comme un switch. Il s'intègre dans un réseau existant sans modifier son schéma d'adressage, ce qui le rend adapté pour :
 - L'**inspection passive** du trafic (ex : surveillance entre un switch et un routeur)
 - Le trafic est filtré via des **règles MAC** plutôt qu'IP, limitant sa polyvalence comparé au mode NAT/Route
 - 🚫 Il peut créer des boucle (car couche 2)
- NAT/Route
 - Principalement utilisé pour la **protection périmétrique**, ce mode opère au **niveau de la couche 3** (réseau) du modèle OSI. Chaque interface possède une **adresse IP distincte** et appartient à un sous-réseau différent. Il permet :
 - La **translation d'adresses réseau (NAT)** pour masquer les IP internes
 - Le **routing avancé** (statique ou dynamique via RIP, OSPF, BGP)
 - Une segmentation réseau via des politiques de sécurité entre zones (LAN, WAN, DMZ) Idéal pour les déploiements où le FortiGate agit comme passerelle principale, offrant une inspection complète du trafic entrant/sortant

L'ordre de filtrage par rapport au règles firewall c'est :

- Tester les règles via numéro de séquence de haut en bas, si ok
 - On inspecte profils de sécurité (Antivirus, web filter, ssl, ..), Si ok
 - NAT, Authentification, journalisation, ..
- Si 1 pas ok → ça dégage

Objets existant pour règle de pare feu : Interface, zone, adresse, utilisateur, service, profils de sécurité, ..

Il existe plusieurs type de règles de pare feu :

- IPV4
- IPV6
- Authentification
- Multicast
- Local

Les règles sont classées par Paire d'interfaces → Par exemple, les règles pour LAN vers DMZ sont classées dans une autre section que celles pour LAN vers WAN.

Zone → Ca permet un regroupement d'interface (Virtuel ou Physique)

Pour les règles de pare feu, il faut toujours mettre au moins une source

Mode d'inspections :

- Mode flux (pas de proxy)
 - Bloque les menaces en temps réel au fur et à mesure que le FortiOS les identifie
- Mode proxy

- Mets le trafic en mémoire tampon pour examiner son entièreté avant de faire qq chose
- Ca permet de faire filtre vidéo, filtre web avec safe search, etc